WEEK 5 – CYBER ATTACKS & DEFENSE (FULL NOTES + PRACTICAL LABS)

SOCIAL ENGINEERING ATTACKS

Social engineering = **tricking people instead of hacking computers**.

A. Phishing

Attackers send fake emails/messages to make victims click a link or enter password.

🧪 Real-Time Example

You receive an email:

From: support@paypaI.com (notice capital I, not L)
Subject: Your account is locked! Verify in 24 hours.

Click here: http://paypal-security-check.com

Victim clicks → enters password → stolen.

🔴 Red Flags to teach students

- Urgency (“24 hours only!”)
- Unknown sender
- Wrong domain (g00gle.com, paypaI.com)
- Poor grammar
- Attachments (.zip, .exe, .scr)

🧪 Practical Activity: Simulate a phishing email (Safe)

1️⃣Create a fake “training only” phishing page

```
mkdir phishing_demo && cd phishing_demo
echo "<h3>Training - Do NOT Enter Real Passwords</h3>" > index.html
python3 -m http.server 8000
```

2️⃣Send a message to students:
Dear Student,
Your Wi-Fi account will expire today. Click below:
http://YOUR-IP:8000

3️⃣ Students click → you ask them to identify red flags.
✔ No real data is collected
✔ Awareness training only

MALWARE ANALYSIS BASICS

Malware = *Software designed to harm, steal, spy, or damage systems*.

Type	What it does	Example
Virus	Injects into files	Old email viruses
Worm	Spreads automatically	WannaCry
Trojan	Looks safe but steals data	Fake games
Ransomware	Locks files for money	WannaCry, LockBit
Spyware	Steals keystrokes, screenshots	Keyloggers
Rootkits	Hides attacker activity	System-level rootkits

Hands-On: Basic Malware Characteristics (Safe, No Real Malware)

1. Identify suspicious files

Use Kali commands:

file suspicious.exe
strings suspicious.exe | less

2. Analyze unknown network connections

sudo netstat -tulnp
sudo ss -tulnp
3. Check running processes
ps aux | grep unknown
top

“Malware often runs hidden processes, connects to unknown IPs, or modifies system files.”

3️⃣ DoS & DDoS ATTACKS

💥 DoS (Denial of Service)

One system floods target → makes service unavailable.

💥 DDoS (Distributed DoS)

Many systems attack at once → 1000× stronger.

Real-Time Examples

- User sends millions of requests to a website → website becomes slow.
- Attackers target a gaming server → all players get disconnected.

Why Students Should Know

Every company faces DDoS attempts. SOC teams monitor this 24/7.

🧪 Practical Activity: Simulate a "Tiny Safe DoS" on your own machine

(Just for learning, does NOT harm your system.)

Using `hping3` (install if needed):

```
sudo apt install hping3
```

Send controlled packets to yourself:

```
sudo hping3 -c 10 -S 127.0.0.1
```

This shows how fast packets can be sent.

👉 **Do NOT perform on external servers** (illegal).
Only on **localhost or your own VMs**.

4️⃣ PASSWORD ATTACKS & AUTHENTICATION

A. Types of Password Attacks

Attack Type	Explanation	Example
Brute Force	Try every combination	aaaa → aaab → aaac
Dictionary Attack	Use common passwords list	rockyou.txt

Credential Stuffing	Leaked passwords reused	“password123” reused
Phishing	Trick victim to type password	fake login page

B. Authentication Factors

Factor	Example
Something you know	password, PIN
Something you have	OTP, mobile, smart card
Something you are	fingerprint, face

Best Practice: Use MFA/2FA

Practical Activity: Crack a test hash using John

Create a weak hash:

```
echo -n "password" | md5sum > hash.txt
```

Crack:

```
john hash.txt --wordlist=/usr/share/wordlists/rockyou.txt
john --show hash.txt
```

Explain:

- Weak passwords crack in seconds
- Strong passphrases take years

5️⃣ SECURITY TOOLS OVERVIEW (Wireshark, Nmap, Metasploit)

A. Wireshark – Packet Sniffer

Used to analyze network traffic.

Use Case:

- Capture HTTP passwords

- Analyze malware communication
- Inspect DNS traffic

🧪 Practical:

Capture POST request:

```
tcp port 8000
```

Follow TCP stream: see username & password in plaintext (HTTP).

B. Nmap – Port Scanner

Used to find open ports, services, vulnerabilities.

🧪 Practical Nmap Commands

```
sudo nmap -sn 192.168.1.0/24           # discover devices
sudo nmap -sV 192.168.1.10             # detect software versions
sudo nmap -p- 192.168.1.10             # scan all ports
sudo nmap --script=vuln 192.168.1.10   # basic vuln scan
```

Students learn:

- What's running on target?
- Which ports open?
- Is SSH open? Is HTTP open?

C. Metasploit – Penetration Testing Framework

Used to exploit vulnerabilities (only in labs!).

Common modules:

- scanner
- exploit
- payloads

🧪 Simple Safe Command

Start Metasploit:

```
sudo msfconsole
```

Search for modules:

```
search ssh
search ftp
```

Do not exploit real systems — only use test VMs.

PRACTICAL ACTIVITIES

These match the Week-5 requirement exactly.

Activity 1 — Simulate a Phishing Email & Identify Red Flags

1. Start a training page:

```
mkdir phish && cd phish
echo "Training Only - Fake Login Page" > index.html
python3 -m http.server 8000
```

2. Tell student to check:
   http://YOUR-IP:8000

3. Ask them to identify red flags:

- Wrong domain
- No HTTPS
- No company logo
- Poor grammar

Activity 2 — Perform an Nmap Port Scan on Local Machine

Scan:

```
sudo nmap -sV 127.0.0.1
```

or on lab network:

```
sudo nmap -sn 192.168.56.0/24
```

Students must submit:

- Screenshot
- Explanation of open ports

STUDENT OUTPUT REQUIREMENTS

For each activity students must submit:

✔ Screenshot of phishing page & red flags list
✔ Nmap port scan results (txt or screenshot)
✔ Answer: “Why is phishing dangerous?”
✔ Answer: “What is the difference between DoS and DDoS?”

SHORT SUMMARY FOR REVISION

- **Phishing tricks people** → attackers don’t need hacking tools.
- **Malware steals, damages, spies**.
- **DoS vs DDoS:** one vs many attackers.
- **Password attacks** show why strong passwords matter.
- **Wireshark/Nmap/Metasploit** are essential security tools.